

SECURITY RISK ASSESSMENT REPORT

Elite Healthcare

Prepared by: JVK Enterprise Holding Solutions | April 2026

1. Executive Summary

This security risk assessment was conducted for Elite Healthcare, a 20-employee outpatient medical clinic that electronically stores and processes Protected Health Information (PHI). The purpose of this assessment is to identify, analyze, and prioritize security risks that may impact the confidentiality, integrity, and availability of patient data. Findings are aligned with the NIST Cybersecurity Framework to provide a structured and actionable remediation roadmap.

2. Organization Overview

- Organization: Elite Healthcare
- Size: 20 employees, single outpatient location
- Services: Patient appointments, electronic medical records (EMR), and billing
- Regulatory scope: HIPAA Privacy and Security Rules

3. Risk Assessment Methodology

Risks were evaluated using a qualitative methodology based on two factors: likelihood of occurrence and impact severity. Each risk was categorized as Low, Medium, High, or Critical. Findings are mapped to the NIST Cybersecurity Framework (CSF) functions: Identify, Protect, Detect, Respond, and Recover.

4. Risk Register

Threat	Likelihood	Impact	Risk Level	NIST Mapping	Recommendation
--------	------------	--------	------------	--------------	----------------

Phishing Attack on Staff Email	HIGH	High	Critical	NIST PR AT - 1	Mandatory security awareness training and email filtering
Unauthorized Access to Patient Records	MEDIUM	High	High	NIST PR AC-1	Air Force role-based access controls and quarterly access review
Ransomware Infection	MEDIUM	Critical	Critical	NIST RS RP-1	Deploy endpoint protection, maintain offline backups, and test recovery plans.
Unencrypted Patient Data on Devices	HIGH	High	Critical	NIST PR DS-1	Enforce full disk encryption on all devices handling PHI
Third-Party Vendor Data Breach	LOW	High	Medium	NIST ID SC-2	Implement vendor risk assessment and Business Associate Agreements

5. Recommendations Summary

- Implement security awareness training immediately; phishing represents the highest-likelihood threat.
-
- Enforce full disk encryption on all devices that store or access PHI.
- Conduct quarterly access reviews and apply least-privilege principles.
- Deploy and regularly test a ransomware recovery plan, ensuring offline backups are functional.
- Require signed Business Associate Agreements (BAAs) from all third-party vendors handling PHI.

6. Conclusion

Elite Healthcare faces several significant cybersecurity risks, particularly related to phishing, unauthorized access, and ransomware. Addressing these risks through the recommendations provided in this report will meaningfully reduce the organization's exposure and support HIPAA compliance. A formal risk assessment should be conducted annually or whenever substantial changes occur in systems, personnel, or operations.